

ĐỊNH DANH TRÊN KHÔNG GIAN MẠNG

Nền tảng eKYC + IdP/SSO — Kiến trúc (Mô hình B)

Một pool người dùng · nhiều relying party (RP/client) · IdP OIDC tự viết · bảo vệ PII bằng Sensitive Data Service. Mô tả theo arc42.

Một issuer, nhiều RP

Tự viết OIDC (Go)

SDS mã hóa PII

Postgres-first

DDD / Clean Architecture

Kafka · Redis · K8s

01 Tổng quan

Ba trụ cột, theo mô hình tập trung (gần UAE PASS), khác hướng SSI/blockchain của NDA Key.

IdP / SSO

OAuth 2.0 / OpenID Connect tự viết. Một issuer, một pool user, nhiều RP/client. Đăng nhập một lần xuyên mọi ứng dụng.

eKYC + IAL

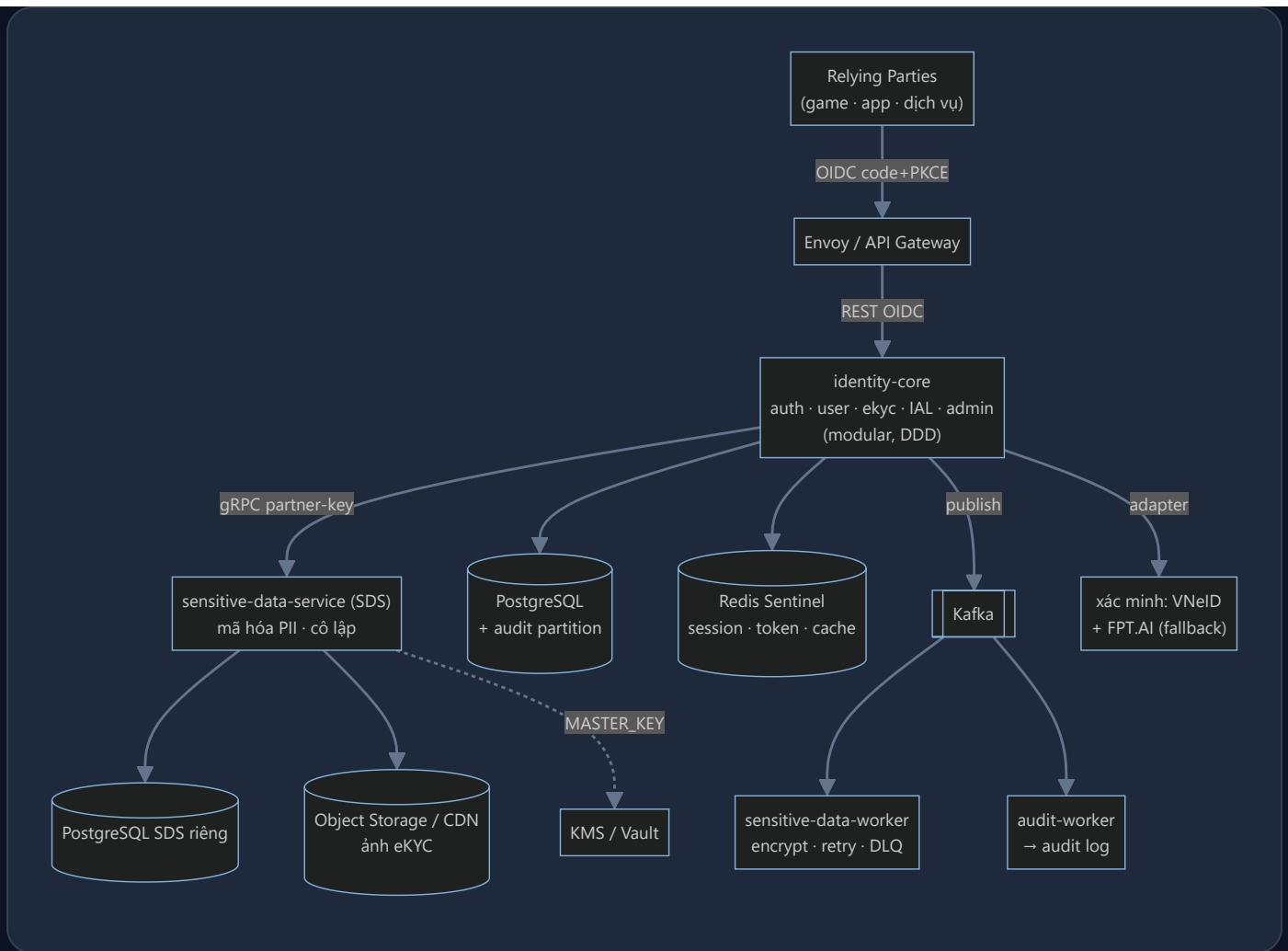
Xác minh người thật qua adapter nhà cung cấp (FPT.AI...). Nâng mức định danh IAL1 (email/SĐT) → IAL2 (đã eKYC).

Sensitive Data Service

Service cô lập, mã hóa toàn bộ PII/KYC bằng mô hình khóa phân cấp có version. Điểm khác biệt mạnh nhất.

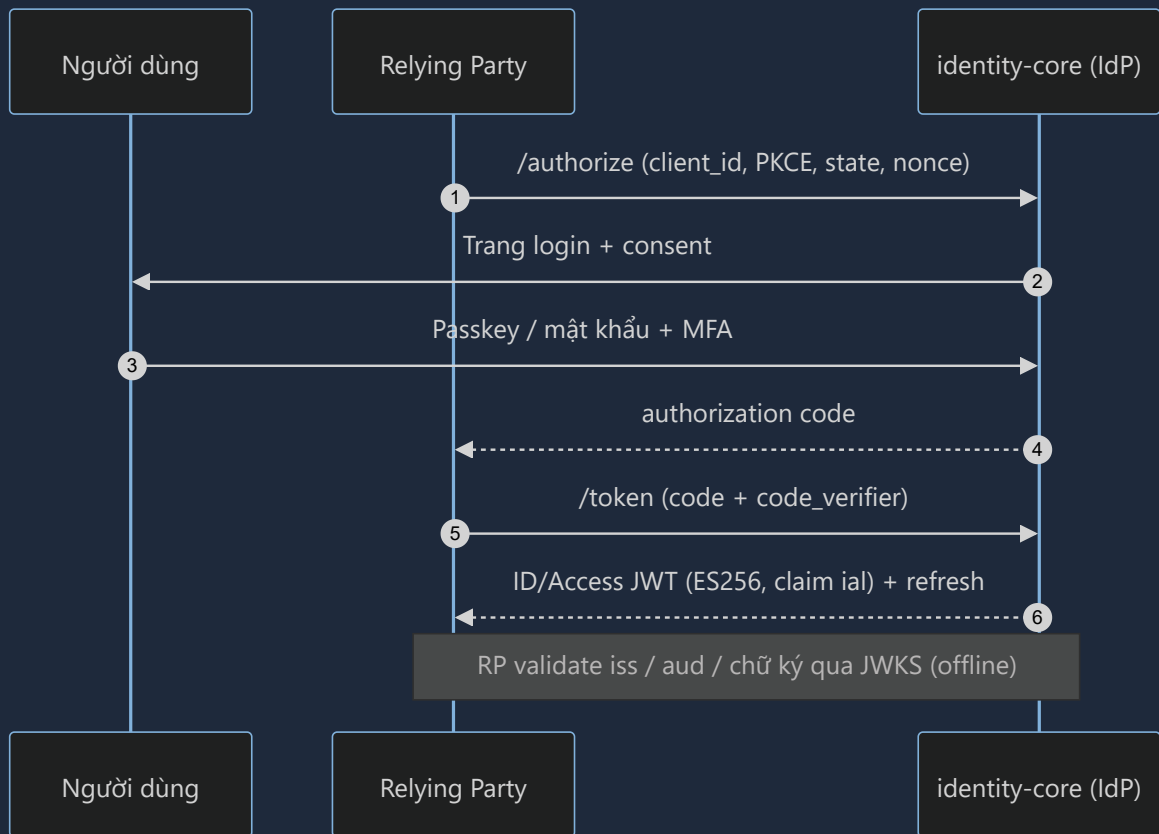
02 Kiến trúc tổng thể

Nền gọn: identity-core (modular, DDD) + SDS (cô lập) + workers. Giao tiếp gRPC nội bộ, REST/OIDC ra ngoài.



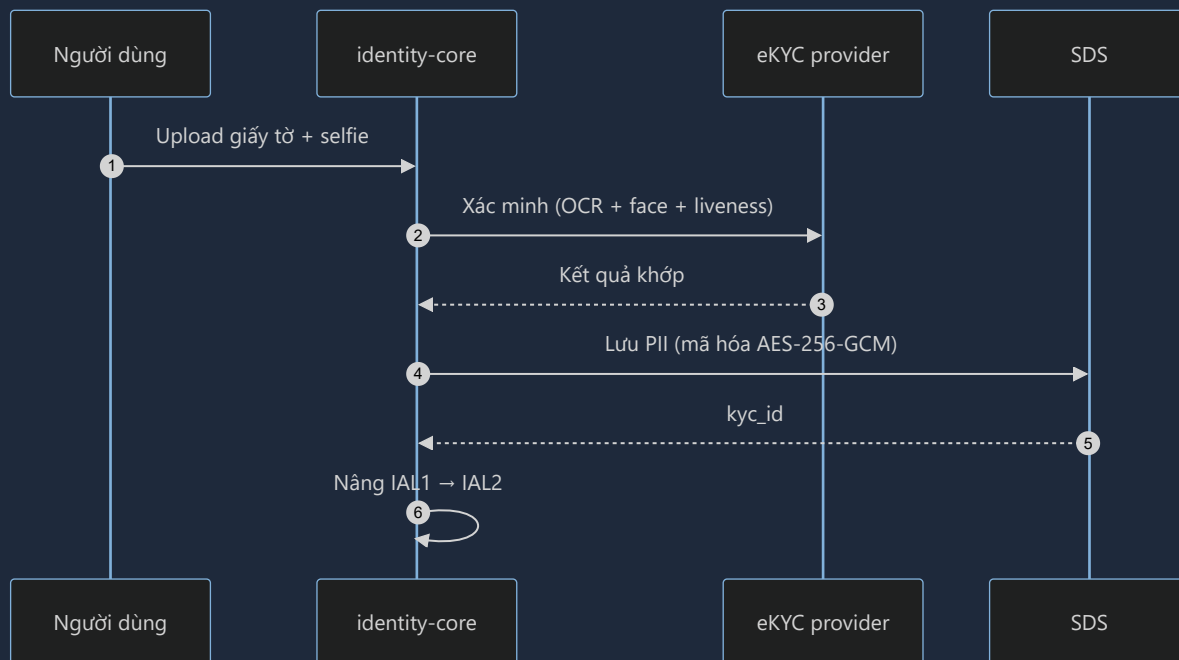
03 Luồng đăng nhập OIDC

Authorization Code + PKCE, một issuer. Token JWT ES256 validate offline qua JWKS.



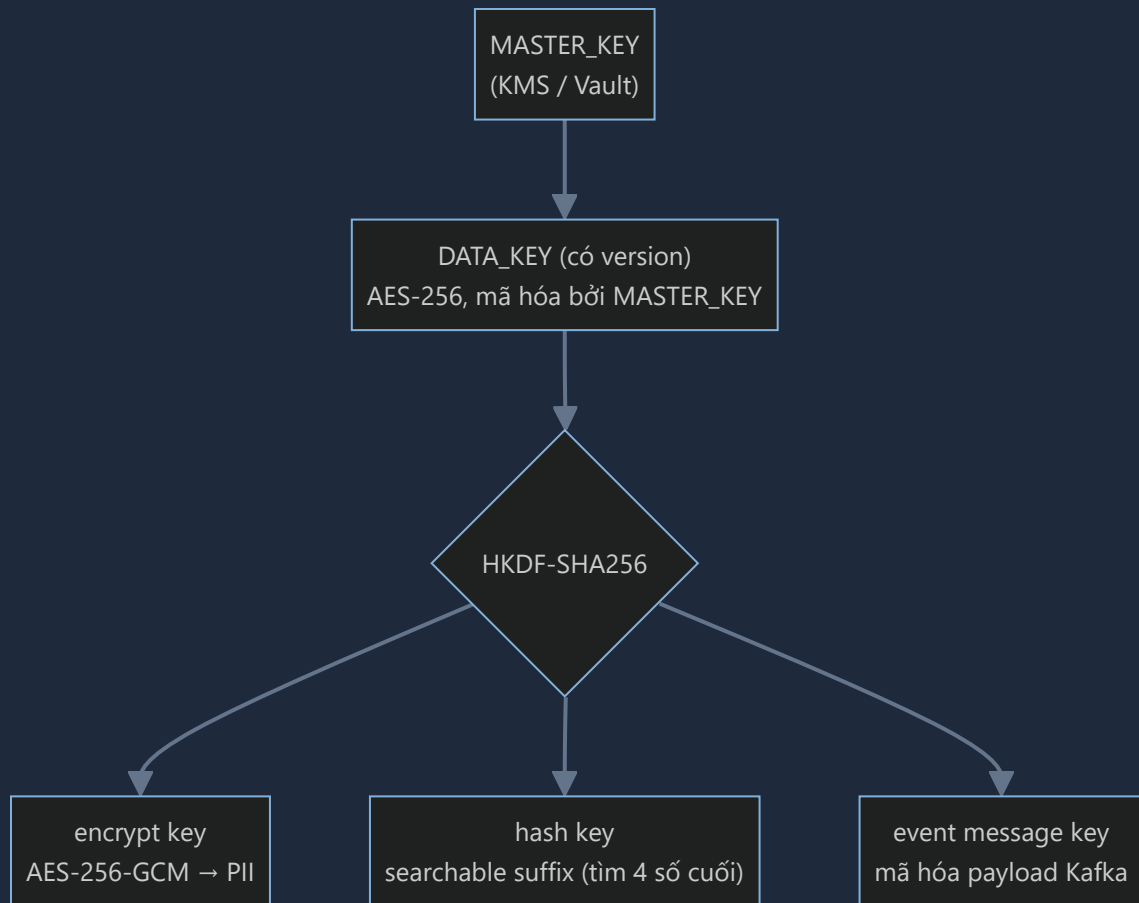
04 Luồng eKYC → nâng IAL

PII không bao giờ ở identity-core dạng plaintext — chỉ giữ kyc_id + ial.



05 Mô hình khóa SDS

MASTER_KEY → DATA_KEY (có version) → khóa dẫn xuất qua HKDF-SHA256. Xoay khóa theo version, blast-radius nhỏ.



06 Tech stack

Bám house style O2O ở mức convention; Postgres-first, một datastore cho MVP.

Go

OAuth2 / OIDC

ory/fosite (token)

chi (router)

DDD + Clean Architecture

CQRS

gRPC + Envoy

PostgreSQL (+ pgvector)

sqlc + pgxpool

goose (migration)

Redis Sentinel

Kafka

Object Storage / CDN (R2/S3)

go-webauthn (Passkey)

JWT ES256 + JWKS

Docker → K8s

OpenTelemetry / SigNoz

Prometheus

07 So sánh benchmark

Plan của ta gần UAE PASS (tập trung, OIDC); NDA Key là hướng SSI/ZKP không chọn.

Tiêu chí	UAE PASS	NDA Key	Plan của ta
Mô hình	Tập trung (quốc gia)	Phi tập trung (SSI/blockchain)	Tập trung, một pool
Giao thức	OAuth2 / OIDC	DID + Verifiable Credentials	OAuth2 / OIDC (tự viết)
SSO + eKYC + cấp độ ĐD	✓	✓	✓
Chữ ký số pháp lý	✓	✓	II roadmap
Kho tài liệu / ví	✓ Vault	✓ ví	II roadmap
VC + ZKP (chia sẻ chọn lọc)	✗	✓	✗ (tập trung)
Gắn ID quốc gia (VNeID...)	✓ Emirates ID	✓ did:nda↔VNeID	✗ cần quyết
Bảo vệ PII mã hóa	vault	ZKP / on-chain	✓ SDS (điểm mạnh)

08

Roadmap

MVP — build mỏng

- OIDC code+PKCE (một issuer), JWKS + xoay khóa
- Login + Passkey/FIDO + MFA + Single-Logout (SLO)
- Token JWT ES256, refresh rotation + reuse-detection
- **eKYC qua VNeID + FPT.AI** → IAL gắn năng lực (gọi SDS)
- SDS: MASTER_KEY→DATA_KEY(version)→HKDF, AES-256-GCM, searchable hash, RBAC theo kyc_id
- Đăng ký & quản trị client/RP, user; audit (Postgres)
- Stateless + Redis + rate limit + object storage

Phase 2 — đích

- Chữ ký số pháp lý (Luật GDĐT 2023) — IAL cao mở khóa
- Kho tài liệu / ví credential
- Verifiable Credentials + ZKP (hướng lai SSI)
- SDK cho bên tích hợp · social login
- Sharding thật · đa-DC/GEO · autoscale · MongoDB cho audit
- Multi-tenant (nếu bán IdP cho tổ chức ngoài)

Định danh trên Không gian mạng · arc42 · Mô hình B (một pool, nhiều RP/client) · 2026-06-06

Tài liệu: docs/superpowers/specs/ — bản đồ kiến trúc · spec identity-core · so sánh benchmark